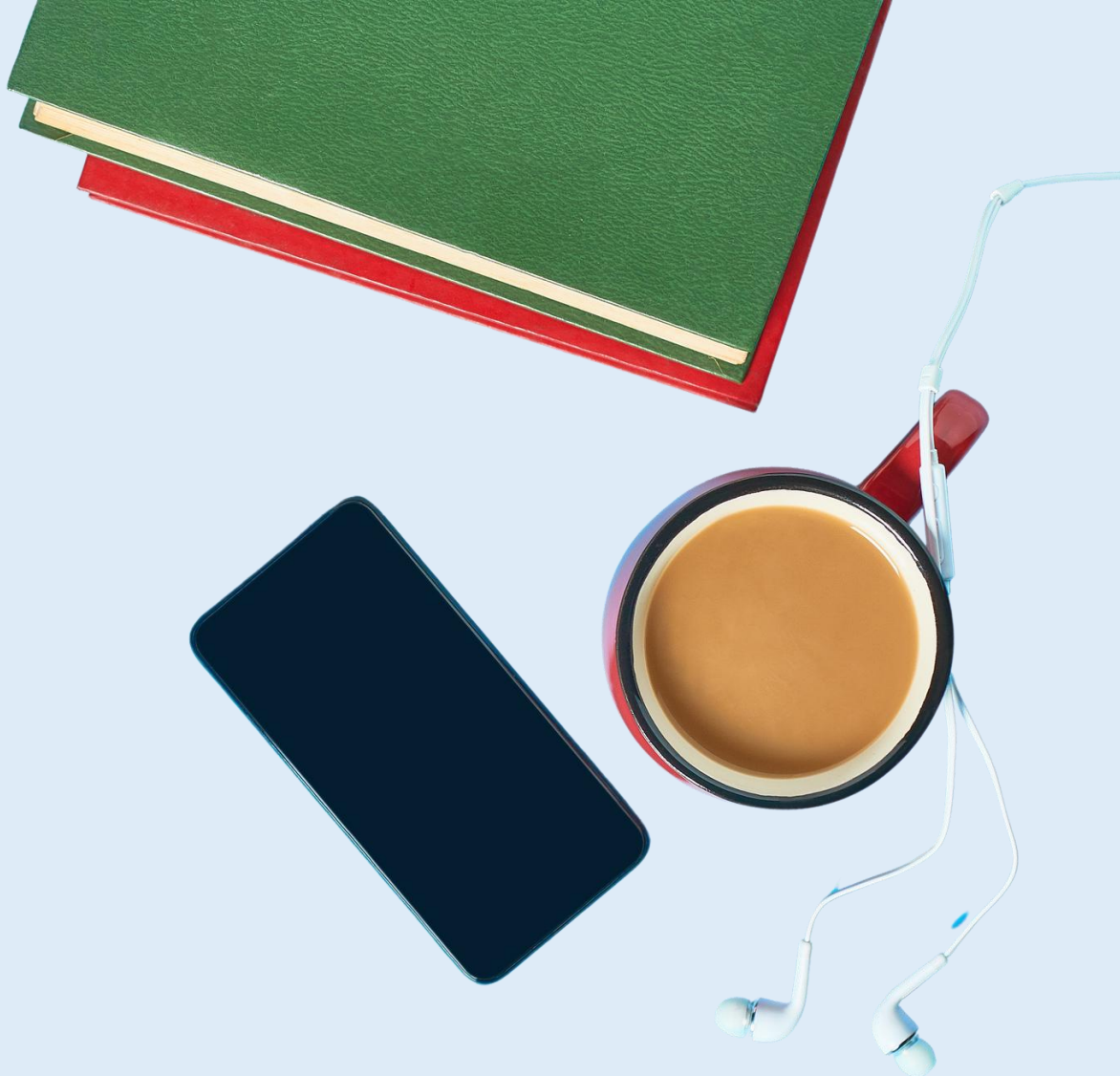


שיעור תרגול

הגנת הפרטיות: תרגול מקרים ואירועים



פרשו את המושגים הבאים:

א. מידע בעל רגישות מיוחדת

ב. מאגר מידע

ג. דיוור ישיר

ד. צמידות מטרה

ה. רמת אבטחה בינונית

ו. מחזיק

מקרים ואירועים

1. רוני היא DPO בחברת כסף-של-אחרים בע"מ. החברה נסחרת בבורסה (חברה ציבורית). החברה אוספת מידע רגיש על 100,000 האנשים האמידים בישראל, כולל שמות, כתובות מגורים, מידע פיננסי, תחומי פעילות, קשרים עסקיים ומשפחתיים וכדו'. החברה משתמשת במידע על מנת לנתח אותו ולהעניק על בסיסו ייעוץ עסקי ואסטרטגי לעסקים שמכוונים למאיון העליון. את המידע עצמו החברה שומרת לעצמה כדי לשמור על תחרותיות.

רוני שואלת, האם החברה מחויבת להודיע לרשות על המאגר? ומה לגבי רישום?

מקרים ואירועים

2. חברת יהושע ובניו בע"מ היא חברת הנהלת חשבונות המחזיקה רשימות עובדים של החברות להן היא מעניקה שירותי חשבות שכר. לחברה 50 לקוחות ובממוצע לכל לקוח שלה יש 5,000 רשומות אודות 350 עובדים, כולל מידע רגיש. מה רמת האבטחה החלה על החברה?

מקרים ואירועים

3. לחברת הלל השכרת רכבים בע"מ ישנו מאגר רשום של לקוחות קיימים, אליו ניגשים כ-8 מעובדי החברה, המשמש לצרכי השכרת הרכבים ללקוחות עסקיים. החברה קיבלה פניה מסטארטפ חדש המפתח מוצר חדשני בתחום השכרת הרכב והוא מעוניין לעשות שימוש במאגר הלקוחות של חברת הלל לצורכי מחקר.

האם חלה עליה חובה להודיע ללקוחות על ההתקשרות עם הסטארטפ? האם מספיק לעדכן את מדיניות הפרטיות באתר?

מקרים ואירועים

4. איתי הוא מנהל אבטחת מידע בחברת חכמו-לוג בע"מ. מתוקף תפקידו הוא התבקש להטמיע את נהלי אבטחת המידע בחברה בהתאם לדרישות תקנות הגנת הפרטיות ובהתאם לתיקון 13. איתי קרא את התקנות בעיון והחל בכתיבת נהלים להטמעה בחברה. בבואו להטמיע נוהל לניהול הרשאות גישה, הבין איתי כי אין לו צורך בנוהל מסודר כי הוא יכול לייצא מתי שירצה את רשימת ההרשאות מתוך מערכות המידע.

האם חברת חכמולוג עומדת בדרישות התקנות בהקשר זה?

מקרים ואירועים

5. חברת DataFlow מפעילה מערכת SaaS המשמשת כ-120 לקוחות.

ביום שני בבוקר, מנהל אבטחת המידע (ה-CISO) מזהה פעילות חריגה בשרת הייצור: נראה כי תוקף חיצוני הצליח להוריד קבצים הכוללים מידע אישי של כ-4,500 משתמשים - שמות, כתובות מייל וקבצים שהועלו על ידי משתמשים. ה-CISO מנתק את השרת מהאינטרנט ומתחיל לעבוד על שחזור. הוא מודיע על האירוע למנכ"ל וליועץ המשפטי, אך אינו מעדכן את ה-DPO כי "עוד לא ברור שיש פה הפרת פרטיות - זה רק אירוע אבטחה". בשעה 14:00, 6 שעות מזיהוי האירוע, ה-DPO מגלה על התקיפה במקרה, כאשר מנהל צוות הפיתוח מספר לו "אגב, הייתה פריצה הבוקר".

בדיון חירום שמתקיים מיד:

- ה-CISO טוען שאולי לא נגנב מידע בפועל ולכן אין מקום לדיווח.
- היועץ המשפטי חושש מנזק תדמיתי ולכן מציע "לחקור עד הסוף לפני שמערבים גורמים חיצוניים".
- המנכ"ל שואל למה ה-DPO לא היה בעניינים קודם.
- ה-DPO טוען שאם היו מעדכנים אותו בזמן, אולי כבר הייתה מתקבלת החלטה לגבי דיווח לרשות או ללקוחות.

בינתיים, חלק מהלקוחות שואלים על תקלות במערכת, והחברה לא בטוחה מה מותר לה לומר. האירוע תקוע, וכל גורם מושך לכיוון אחר - כאשר השעון ממשיך לתקתק מבחינת חובת הדיווח האפשרית. מהי אחריות ה-DPO בתוך הארגון בעת אירוע אבטחת מידע וביחס להנהלה, ל-CISO וליועץ המשפטי? כיצד אתם הייתם פועלים?

מקרים ואירועים

6. יורי הוא מתכנת העובד בחברת הייטק גדולה ומוכרת בתחום טיוב אחסון וגיבוי נתונים ודאטה. בשעות הפנאי שלו הוא מעניק שירותי QA לחברות אבטחת מידע.

ביום 1.5 חברת פצצה גרעינית, המספקת פתרונות אבטחת מידע לאתרי אינטרנט עסקיים, ביקשה לשכור את שירותיו של יורי ולשם כך, באותו יום, פתח יורי חשבון בשרתי אחסון של מונגו DB.

ביום 7.5 הוא העתיק את היוזרים של הלקוח לשרת, על מנת לבצע אנליזה על הלוגים אבל מכיוון שהתהליך התארך הוא השאיר את המחשב לעבוד ומיהר לצאת להגיע בזמן לדרכי.

לאחר כשבוע נכנס יורי לחשבון שלו בשרת האחסון על מנת לסגור אותו, ולהפתעתו גילה שכל המידע נמחק ומופיעה שם הודעה כי המידע נמצא בידי תוקף המבקש ביטקוין אחד בתמורה למידע, וכי אם לא ייענה בתוך 48 שעות המידע יופץ בדארקנט. מחקירה פורנזית שערכה החברה עולה כי קיימים עשרות לוגים של כניסה, קריאה ומחיקה בדאטהבייס כולם בהפרש של מאיות השניה אחד מהשני, החל מתאריך 4.5.

האם מדובר באירוע אבטחה? האם מדובר באירוע אבטחה חמור?